DBMS 계정 관리 보안 점검

D-03 / D-04 | 등급: 상

D-03

비밀번호 사용 기간 및 복잡도 설정

D-04

관리자 권한 최소 권한 원칙 적용

D-03 개요: 비밀번호 정책

점검 목적

비밀번호 사용 기간 및 복잡도 설정 유무를 점검하여 무차별 대입 공격(Brute Force), 사전 대입 공격(Dictionary Attack) 등 비인가자의 추측 공격에 대한 대비 여부를 확인

판단 기준

- **양호:** 기관 정책에 맞게 비밀번호 사용 기간 및 복잡도 설정이 적용된 경우
- **취약:** 기관 정책에 맞게 설정이 적용되지 않은 경우

점검 대상

Oracle DB, MSSQL, MySQL, Altibase, Tibero, PostgreSQL 등

⚠ 비밀번호 정책 미설정 시 비인가자가 추측 공격으로 획득한 계정을 이용해 DB에 직접 접근할 수 있는 위험이 존재합니다.

D-03 조치: Oracle DB 비밀번호 정책

Oracle DB에서는 **PROFILE**을 통해 비밀번호 정책을 설정합니다. 아래 단계에 따라 적용하세요.

1

PASSWORD_LIFE_TIME 변경

```
ALTER PROFILE <프로파일명> LIMIT
PASSWORD_LIFE_TIME xx;
```

2

사용자 프로파일 변경

```
ALTER USER <계정명> PROFILE <변경
할 프로파일명>;
```

3

비밀번호 정책 일괄 설정

```
ALTER PROFILE <프로파일명> LIMIT
 FAILED_LOGIN_ATTEMPTS 3
 PASSWORD_LIFE_TIME 30
 PASSWORD_REUSE_TIME 30
 PASSWORD_VERIFY_FUNCTION
verify_function
 PASSWORD_GRACE_TIME 5;
```

D-03 조치: MSSQL 비밀번호 정책

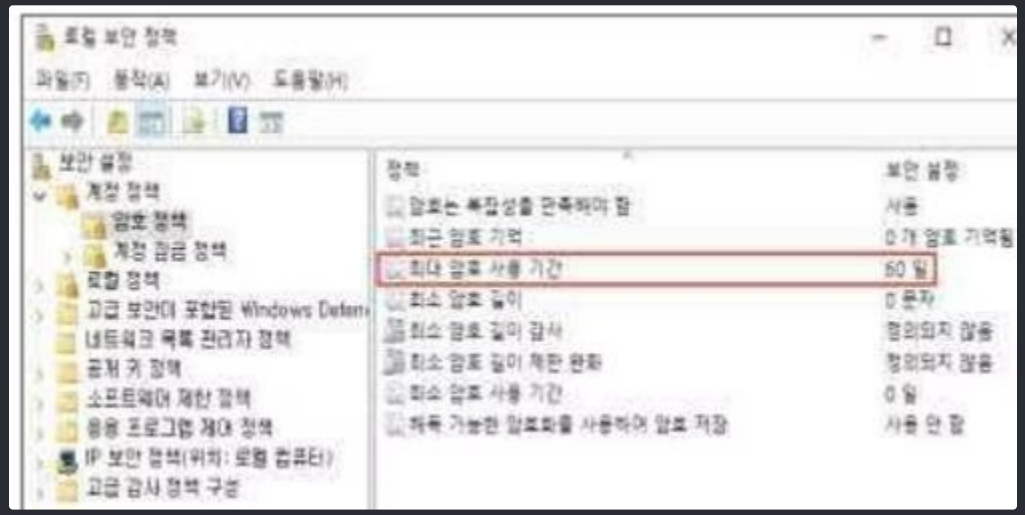
MSSQL은 **암호 만료 강제 적용** 설정과 OS의 **로컬 보안 정책**을 함께 구성해야 합니다.

Step 1–2: 암호 만료 강제 적용

보안 > 로그인 > 각 로그인 계정 > 속성에서 **"암호 만료 강제 적용"** 체크박스를 활성화합니다.

Step 3: OS 암호 정책 설정

[관리 도구] > [로컬 보안 정책] > [계정 정책] > [암호 정책] > **최대 암호 사용 기간: 60일** 설정



D-03 조치: MySQL / Altibase / Tibero

MySQL 복잡도 설정

```
INSTALL COMPONENT
'file://component_validate_password';
SET GLOBAL validate_password.policy
= 'MEDIUM';
SET GLOBAL
validate_password.length = 8;
SET GLOBAL
validate_password.mixed_case_count
= 1;
SET GLOBAL
validate_password.number_count = 1;
SET GLOBAL
validate_password.special_char_count
= 1;
```

LifeTime: `SET GLOBAL default_password_lifetime=90;`

Altibase 정책 설정

```
ALTER USER 계정명 LIMIT
 (FAILED_LOGIN_ATTEMPTS 7,
  PASSWORD_LOCK_TIME 7,
  PASSWORD_LIFE_TIME 90,
  PASSWORD_VERIFY_FUNCTION
verify_function);
```

Tibero PROFILE 생성

```
CREATE PROFILE prof LIMIT
  failed_login_attempts 3
  password_lock_time 1/1440
  password_life_time 90
  password_reuse_max 10
  password_grace_time 10
  password_verify_function
verify_function;
```

ⓘ MySQL은 Linux(`/etc/my.cnf`) 또는 Windows(`my.ini`) 설정 파일에 정책을 추가하여 영구 적용할 수 있습니다.

D-04 개요: 관리자 권한 최소화

점검 목적

관리자 권한이 필요한 계정과 그룹에만 권한을 부여하여 권한 남용을 방지하고, 계정 유출 시 비인가자의 DB 접근 가능성을 최소화

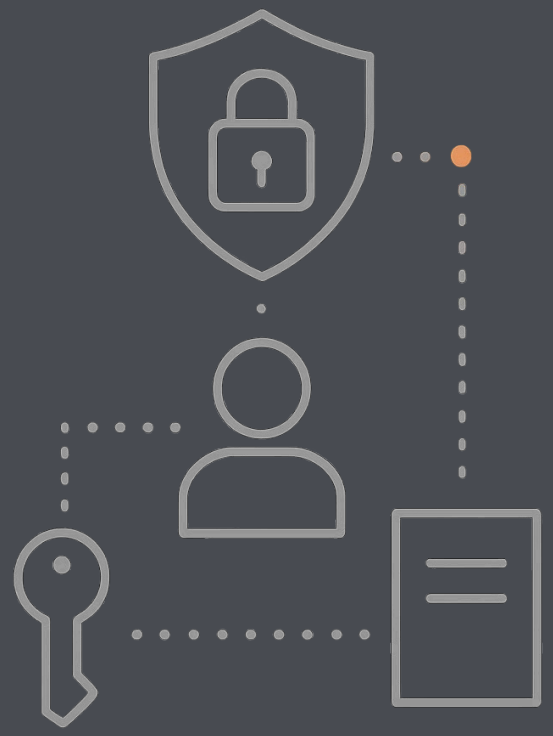
판단 기준

- **양호:** 관리자 권한이 필요한 계정 및 그룹에만 권한이 부여된 경우
- **취약:** 관리자 권한이 불필요한 계정 및 그룹에 권한이 부여된 경우

점검 대상

Oracle DB, MSSQL, MySQL, Altibase, Tibero, PostgreSQL, Cubrid 등

⚠ 관리자 권한이 과도하게 부여된 계정이 유출될 경우 비인가자가 DB 전체에 접근할 수 있는 심각한 위험이 존재합니다.



D-04 조치: Oracle DB / MSSQL 관리자 권한

Oracle DB

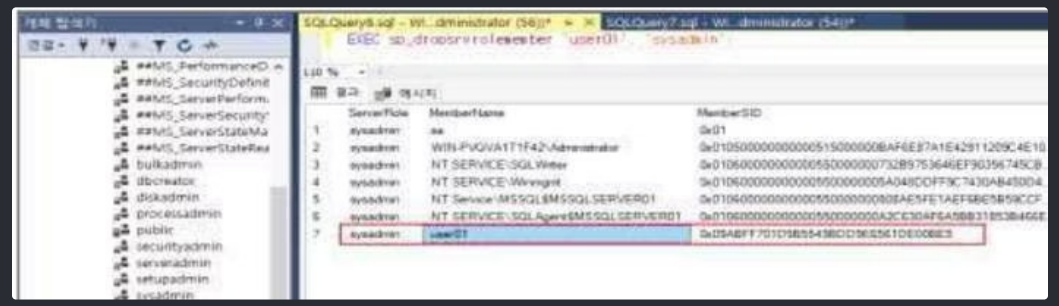
SYSDBA 권한 및 Admin 부적합 계정 점검 후 불필요한 권한 제거:

```
-- 권한 확인
SELECT * FROM DBA_SYS_PRIVS WHERE GRANTEE = '계정명';
-- 권한 회수
REVOKE <권한> FROM <계정명>;
-- 필요 권한만 부여
GRANT <권한> ON <테이블명> TO <계정명>;
GRANT <Role_name> TO <계정명>;
```

MSSQL

sysadmin 서버 역할의 불필요한 계정 확인 후 삭제:

```
EXEC sp_droprolemember 'user01', 'sysadmin';
```



D-04 조치: MySQL / Altibase / Tibero 관리자 권한

MySQL — SUPER 권한 관리

```
-- SUPER 권한 보유 계정 확인
SELECT GRANTEE FROM
INFORMATION_SCHEMA.USER_PRIVI
LEGES
WHERE PRIVILEGE_TYPE = 'SUPER';
-- 불필요한 SUPER 권한 회수
REVOKE SUPER ON *.* FROM '<계정
명>';
FLUSH PRIVILEGES;
```

Altibase — 시스템 권한 점검

grantee_id, user_id, priv_id를 각각 조회하여 일반 사용자에게 기본 권한(CREATE SESSION, CREATE TABLE 등) 외 추가 권한이 부여된 경우 해당 권한을 삭제합니다.

Tibero — 일반 계정 권한 확인

`SELECT * FROM dba_sys_privs;` 결과에서 일반 계정(예: TEST1)에 ALTER SYSTEM, CREATE TABLESPACE 등 불필요한 시스템 권한이 부여된 경우 권한을 삭제합니다.

D-04 조치: PostgreSQL / Cubrid 관리자 권한

PostgreSQL

모든 사용자 확인 후 불필요한 관리자 권한 회수:

```
-- 사용자 확인
SELECT username, usesuper FROM pg_shadow;
-- 권한 회수
ALTER ROLE <계정명> NOSUPERUSER;
ALTER ROLE <계정명> NOCREATEROLE;
ALTER ROLE <계정명> NOCREATEDB;
ALTER ROLE <계정명> NOREPLICATION;
ALTER ROLE <계정명> NOBYPASSRLS;
```

Cubrid

DBA 권한 보유 계정 확인 후 불필요한 권한 회수 또는 계정 삭제:

```
-- DBA 권한 계정 확인
SELECT a.name FROM db_user a,
 table(direct_groups) AS t(roles)
 WHERE roles.name = 'DBA';
-- 권한 일괄 회수
REVOKE ALL PRIVILEGES ON test
 FROM 'GRANT_TEST';
-- 불필요 계정 삭제
DROP USER 'GRANT_TEST';
-- 신규 계정 생성
CREATE USER test_db PASSWORD 'pw'
 GROUPS DB_USER;
```

핵심 요약 및 조치 체크리스트

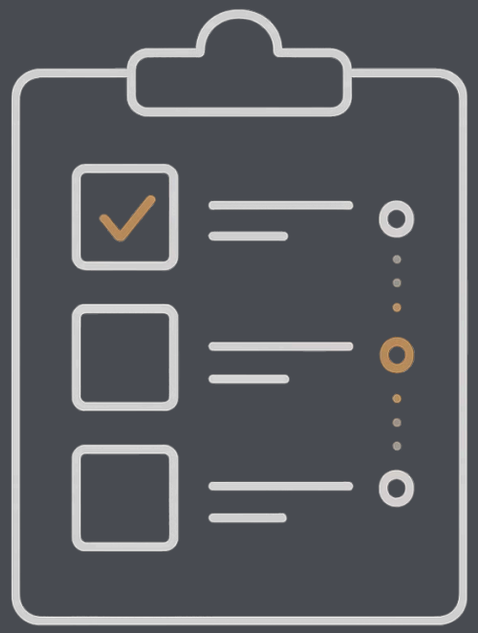
D-03: 비밀번호 정책

- 사용 기간(LifeTime) 및 복잡도 설정 적용
- 실패 횟수 제한, 재사용 제한 포함
- Oracle, MSSQL, MySQL, Altibase, Tibero 각각 적용

D-04: 최소 권한 원칙

- 관리자 권한은 필요한 계정에만 부여
- 불필요한 권한은 즉시 REVOKE
- Oracle, MSSQL, MySQL, Altibase, Tibero, PostgreSQL, Cubrid 적용

조치 시 유의사항

- D-03: 주기적인 비밀번호 변경 필요
- D-04: 일반적인 경우 서비스 영향 없음
- 정책 적용 전 현행 계정 현황 반드시 확인

두 항목 모두 **등급 "상"**으로, 기관 보안 정책에 맞는 즉각적인 조치가 필요합니다.